INSTITUTO FEDERAL DE EDUCAÇÃO, CIÊNCIA E TECNOLOGIA DE SÃO PAULO - CATANDUVA
CURSO SUPERIOR TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS
Disciplina: Gestão de TI - 2º semestre 2026
Professores: **Igor Calebe Zadi e Fábio Viana**

Atividade 04 — Planejamento de um Dashboard de Governança de TI

Equipe: Ana Letícia (Líder), Danyell, Eduardo Lucas Lemes Januario e Guilherme Batista

Cenário: rede de hospitais altamente dependente de TI (prontuário eletrônico, exames e imagens, comunicação interna, autenticação, rede e sistemas administrativos), cuja direção precisa saber se os investimentos em TI contribuem para a continuidade dos serviços, a segurança das informações, a eficiência dos processos e a qualidade do atendimento.

Parte 1 — Compreendendo o problema

Aspecto/problema identificado	Possível impacto para a organização
1. Indisponibilidade dos sistemas clínicos críticos (prontuário eletrônico – PEP, laboratório, sistema de imagens – PACS)	Atrasos e interrupções no atendimento, uso de contingência em papel, risco de erro clínico por falta de histórico do paciente, cancelamento de exames e cirurgias e queda na qualidade assistencial.
2. Volume de incidentes e demora na resolução de chamados	Médicos, enfermeiros e setores administrativos ficam parados ou trabalham de forma improvisada; filas maiores, retrabalho, insatisfação dos usuários e perda de produtividade.
3. Riscos de segurança da informação (ransomware, phishing, vulnerabilidades não corrigidas, acessos indevidos)	Paralisação de sistemas por ataque, vazamento de dados sensíveis de pacientes, adulteração de prontuários, prejuízo financeiro e danos graves à reputação do hospital.
4. Proteção de dados pessoais e conformidade (LGPD, normas do CFM para prontuário, exigências de acreditação)	Sanções da ANPD, processos judiciais, perda de certificações e acreditações hospitalares e questionamentos de órgãos reguladores e convênios.
5. Custos e retorno dos investimentos em TI	Sem clareza sobre gastos e resultados, a direção não consegue justificar investimentos, priorizar projetos ou cortar despesas sem valor, o que gera desperdício ou falta de recursos em áreas críticas.
6. Capacidade e manutenção da infraestrutura (rede, servidores, armazenamento, backup e equipamentos obsoletos)	Lentidão nos sistemas, falhas inesperadas, falta de espaço para exames de imagem, risco de perda definitiva de dados sem backup confiável e custos emergenciais maiores.

Parte 2 — Informação para quem? Informação para decidir o quê?

Problema ou necessidade	Quem precisa da informação?	O que precisa saber?	Que decisão pode apoiar?
Indisponibilidade dos sistemas clínicos	Diretoria clínica e executiva; gerente de infraestrutura; equipe de monitoramento (NOC)	Quanto tempo cada sistema crítico ficou fora do ar, quais unidades foram afetadas, a causa e se há tendência de piora	Investir em redundância/alta disponibilidade, acionar plano de contingência, cobrar fornecedores, priorizar correções
Incidentes e demora no atendimento de chamados	Coordenador do service desk; gerente de serviços de TI	Quantos chamados estão abertos, quantos estão atrasados, quais setores e sistemas geram mais chamados	Remanejar técnicos, rever prioridades, criar treinamentos para usuários, revisar contratos de suporte
Riscos de segurança da informação	Gestor de segurança (CISO); diretoria executiva; analistas de segurança	Quais riscos críticos existem, se as vulnerabilidades estão sendo corrigidas no prazo e se houve tentativas de ataque ou acesso indevido	Aprovar investimento em segurança, priorizar correções, bloquear acessos, aceitar ou tratar riscos

Problema ou necessidade	Quem precisa da informação?	O que precisa saber?	Que decisão pode apoiar?
Proteção de dados e conformidade	Encarregado de dados (DPO); jurídico; diretoria	O nível de atendimento aos requisitos da LGPD, as não conformidades pendentes e os incidentes com dados pessoais	Definir planos de adequação, comunicar incidentes à ANPD, priorizar ações corretivas antes de auditorias
Custos e retorno da TI	Diretoria financeira; CIO/gerente de TI	Quanto foi gasto em relação ao orçado, em quê, e quais benefícios os projetos entregaram	Aprovar, adiar ou cancelar projetos; realocar orçamento; renegociar contratos
Capacidade da infraestrutura	Gerente de infraestrutura; analistas de redes e servidores	Uso de CPU, memória, armazenamento e links; sucesso dos backups; equipamentos em fim de vida	Planejar compras e ampliações, antecipar manutenções, refazer backups falhos, substituir equipamentos

Parte 3 — Organizando as informações nos níveis da organização

Nível	Quem utilizará?	O que precisa acompanhar?	Que decisão deverá tomar?
Estratégico	Diretoria executiva, diretoria clínica, diretoria financeira, conselho e CIO	Disponibilidade global dos serviços críticos, nível de risco de segurança, conformidade com a LGPD e regulamentações, custo da TI e retorno dos investimentos	Aprovar ou redirecionar investimentos, definir prioridades de TI alinhadas ao negócio, decidir sobre tratamento ou aceitação de riscos
Tático	Gerente de TI, gerentes de infraestrutura e de serviços, CISO, DPO	Cumprimento de SLAs, tempo de resolução de incidentes, tendência de chamados, execução orçamentária, correção de vulnerabilidades, capacidade dos recursos	Realocar equipes e recursos, ajustar processos e contratos, planejar capacidade, priorizar correções e projetos
Operacional	Service desk, NOC, analistas de suporte, redes, servidores e segurança	Chamados em fila e atrasados, alertas de monitoramento, status dos servidores e links, resultado dos backups, alertas de acessos suspeitos	Escalonar chamados, acionar fornecedor, reiniciar ou corrigir serviços, refazer backups, bloquear contas suspeitas

Relação entre os níveis: um backup que falha repetidamente (operacional) aumenta o risco de perda de dados e atrasa correções (tático), o que se reflete no índice de risco e na continuidade do atendimento (estratégico).

Parte 4 — Descobrindo os indicadores

Foram selecionados 11 indicadores, inspirados em práticas de governança e gestão de serviços (COBIT 2019, ITIL 4, ISO/IEC 27001/27002 e LGPD), contemplando os três níveis.

Nome do indicador	E1 — Disponibilidade dos sistemas clínicos críticos
Nível	Estratégico
Problema ou objetivo relacionado	Indisponibilidade dos sistemas clínicos (problema 1)
O que ele mede?	Percentual do tempo em que PEP, laboratório e PACS ficaram disponíveis para uso
Por que é importante neste cenário?	Sistemas fora do ar afetam diretamente o atendimento e a segurança do paciente; responde à dúvida da direção sobre continuidade dos serviços
Quem utilizará essa informação?	Diretoria executiva e clínica, CIO
Que decisão poderá apoiar?	Investir em redundância, alta disponibilidade e contratos com fornecedores
Como pode ser calculado ou obtido?	(Tempo total − tempo de indisponibilidade não planejada) ÷ tempo total × 100, por sistema e consolidado
Possível fonte dos dados	Ferramenta de monitoramento (ex.: Zabbix) e registros de incidentes
Periodicidade de acompanhamento	Mensal (com visão acumulada do ano)
Meta ou limite de alerta sugerido	Meta ≥ 99,9%; atenção entre 99,5% e 99,9%; alerta < 99,5%

Nome do indicador	E2 — Riscos críticos de segurança tratados no prazo
Nível	Estratégico
Problema ou objetivo relacionado	Riscos de segurança da informação (problema 3)
O que ele mede?	Percentual dos riscos classificados como críticos/altos que tiveram o plano de tratamento concluído no prazo
Por que é importante neste cenário?	Mostra se a organização está reduzindo sua exposição a ataques e vazamentos de dados de pacientes
Quem utilizará essa informação?	Diretoria executiva, CISO
Que decisão poderá apoiar?	Aprovar recursos para segurança, aceitar ou tratar riscos, cobrar responsáveis
Como pode ser calculado ou obtido?	Riscos críticos tratados no prazo ÷ total de riscos críticos com prazo vencido no período × 100
Possível fonte dos dados	Registro de riscos (análise conforme ISO/IEC 27005)
Periodicidade de acompanhamento	Trimestral
Meta ou limite de alerta sugerido	Meta ≥ 90%; alerta < 75%

Nome do indicador	E3 — Índice de conformidade com a LGPD
Nível	Estratégico
Problema ou objetivo relacionado	Proteção de dados e conformidade (problema 4)
O que ele mede?	Percentual dos requisitos de proteção de dados atendidos pela organização
Por que é importante neste cenário?	Dados de saúde são sensíveis pela LGPD; falhas geram sanções e perda de confiança
Quem utilizará essa informação?	Diretoria, DPO, jurídico
Que decisão poderá apoiar?	Priorizar ações de adequação e investimentos em privacidade
Como pode ser calculado ou obtido?	Requisitos atendidos ÷ requisitos avaliados × 100 (checklist de auditoria)
Possível fonte dos dados	Auditorias internas, relatórios do DPO, registro de incidentes com dados pessoais
Periodicidade de acompanhamento	Semestral (incidentes com dados: mensal)
Meta ou limite de alerta sugerido	Meta ≥ 95%; alerta < 85% ou qualquer incidente com dados sem tratamento

Nome do indicador	T1 — Cumprimento de SLA dos chamados
Nível	Tático
Problema ou objetivo relacionado	Incidentes e demora no atendimento (problema 2)
O que ele mede?	Percentual de chamados resolvidos dentro do prazo acordado por prioridade
Por que é importante neste cenário?	Mostra se a TI atende às áreas assistenciais no tempo necessário
Quem utilizará essa informação?	Gerente de serviços, coordenador do service desk
Que decisão poderá apoiar?	Remanejar equipe, rever prioridades e contratos de suporte
Como pode ser calculado ou obtido?	Chamados resolvidos no prazo ÷ total de chamados encerrados × 100
Possível fonte dos dados	Sistema de chamados (ex.: GLPI)
Periodicidade de acompanhamento	Semanal e mensal
Meta ou limite de alerta sugerido	Meta ≥ 95%; alerta < 90%

Nome do indicador	T2 — Tempo médio de restauração de incidentes críticos (MTTR)
Nível	Tático
Problema ou objetivo relacionado	Indisponibilidade dos sistemas clínicos (problema 1)
O que ele mede?	Tempo médio entre a abertura e a restauração de incidentes críticos
Por que é importante neste cenário?	Quanto mais tempo um sistema crítico fica parado, maior o impacto no paciente
Quem utilizará essa informação?	Gerente de infraestrutura, gerente de TI
Que decisão poderá apoiar?	Melhorar procedimentos de resposta, treinar equipe, rever fornecedores
Como pode ser calculado ou obtido?	Soma dos tempos de restauração ÷ número de incidentes críticos
Possível fonte dos dados	Sistema de chamados e monitoramento
Periodicidade de acompanhamento	Mensal
Meta ou limite de alerta sugerido	Meta ≤ 1 h; alerta > 2 h

Nome do indicador	T3 — Execução orçamentária de TI
Nível	Tático
Problema ou objetivo relacionado	Custos e retorno da TI (problema 5)
O que ele mede?	Relação entre o valor realizado e o orçado para TI (custeio e investimentos)
Por que é importante neste cenário?	Permite demonstrar controle de custos e embasar a prestação de contas à direção
Quem utilizará essa informação?	Gerente de TI, diretoria financeira
Que decisão poderá apoiar?	Realocar orçamento, adiar ou antecipar compras e projetos
Como pode ser calculado ou obtido?	Valor realizado ÷ valor orçado no período × 100
Possível fonte dos dados	Sistema financeiro/ERP e controle de contratos
Periodicidade de acompanhamento	Mensal
Meta ou limite de alerta sugerido	Faixa ideal 95%–105%; alerta fora de 90%–110%

Nome do indicador	T4 — Vulnerabilidades críticas corrigidas no prazo
Nível	Tático
Problema ou objetivo relacionado	Riscos de segurança (problema 3)
O que ele mede?	Percentual de vulnerabilidades críticas/altas corrigidas dentro do prazo definido
Por que é importante neste cenário?	Vulnerabilidades abertas são a principal porta de entrada de ransomware
Quem utilizará essa informação?	CISO, gerente de infraestrutura
Que decisão poderá apoiar?	Priorizar janelas de manutenção e correções, isolar sistemas legados
Como pode ser calculado ou obtido?	Vulnerabilidades corrigidas no prazo ÷ vulnerabilidades identificadas × 100
Possível fonte dos dados	Ferramenta de varredura de vulnerabilidades e gestão de atualizações
Periodicidade de acompanhamento	Quinzenal
Meta ou limite de alerta sugerido	Meta ≥ 95% (críticas em até 15 dias); alerta < 85%

Nome do indicador	O1 — Chamados em aberto e atrasados por prioridade
Nível	Operacional
Problema ou objetivo relacionado	Incidentes e demora no atendimento (problema 2)
O que ele mede?	Quantidade de chamados abertos, por prioridade, setor e sistema, e quantos já passaram do prazo
Por que é importante neste cenário?	Permite agir antes que o SLA seja descumprido
Quem utilizará essa informação?	Service desk, analistas de suporte
Que decisão poderá apoiar?	Escalonar chamados, redistribuir tarefas entre técnicos
Como pode ser calculado ou obtido?	Contagem em tempo real de chamados abertos e atrasados
Possível fonte dos dados	Sistema de chamados
Periodicidade de acompanhamento	Tempo real/diária
Meta ou limite de alerta sugerido	Alerta: qualquer chamado crítico atrasado ou fila > 20% acima da média

Nome do indicador	O2 — Taxa de sucesso dos backups
Nível	Operacional
Problema ou objetivo relacionado	Capacidade e manutenção da infraestrutura (problema 6)
O que ele mede?	Percentual das rotinas de backup concluídas com sucesso
Por que é importante neste cenário?	Sem backup confiável, um ataque ou falha pode causar perda definitiva de prontuários
Quem utilizará essa informação?	Analistas de infraestrutura
Que decisão poderá apoiar?	Refazer backups falhos, corrigir rotinas, ampliar armazenamento
Como pode ser calculado ou obtido?	Backups concluídos com sucesso ÷ backups programados × 100 (e testes de restauração)
Possível fonte dos dados	Software de backup
Periodicidade de acompanhamento	Diária
Meta ou limite de alerta sugerido	Meta 100%; alerta em qualquer falha em sistema crítico

Nome do indicador	O3 — Uso de recursos da infraestrutura
Nível	Operacional
Problema ou objetivo relacionado	Capacidade da infraestrutura (problema 6)
O que ele mede?	Uso de CPU, memória, armazenamento e links de rede dos servidores que sustentam os sistemas críticos
Por que é importante neste cenário?	Recursos saturados causam lentidão e quedas nos sistemas clínicos
Quem utilizará essa informação?	NOC, analistas de redes e servidores
Que decisão poderá apoiar?	Liberar espaço, redistribuir carga, solicitar ampliação
Como pode ser calculado ou obtido?	Percentual de uso medido continuamente por servidor/link
Possível fonte dos dados	Ferramenta de monitoramento
Periodicidade de acompanhamento	Tempo real
Meta ou limite de alerta sugerido	Atenção ≥ 75%; alerta ≥ 85% de uso

Nome do indicador	O4 — Alertas de acesso suspeito
Nível	Operacional
Problema ou objetivo relacionado	Riscos de segurança e proteção de dados (problemas 3 e 4)
O que ele mede?	Número de tentativas de login falhas, acessos fora do horário ou fora do perfil ao prontuário e alertas do antivírus/EDR
Por que é importante neste cenário?	Detecta ataques e acessos indevidos a dados de pacientes no início
Quem utilizará essa informação?	Analistas de segurança
Que decisão poderá apoiar?	Bloquear contas, investigar acessos, acionar resposta a incidentes
Como pode ser calculado ou obtido?	Contagem de eventos de segurança por tipo e gravidade
Possível fonte dos dados	Logs de autenticação (Active Directory), SIEM, logs de acesso do PEP
Periodicidade de acompanhamento	Tempo real/diária
Meta ou limite de alerta sugerido	Alerta: eventos acima da média ou qualquer acesso indevido ao prontuário confirmado

Parte 5 — Construindo uma cadeia de indicadores

Problema escolhido (mais crítico): indisponibilidade dos sistemas clínicos críticos, pois afeta diretamente o atendimento e a segurança do paciente.

Elemento da cadeia	Descrição
Objetivo do negócio	Garantir atendimento contínuo, seguro e de qualidade aos pacientes
Objetivo da TI	Manter os sistemas clínicos críticos (PEP, laboratório, PACS) disponíveis e com desempenho adequado
Indicador estratégico	E1 — Disponibilidade dos sistemas clínicos críticos (%)
Indicador tático	T2 — Tempo médio de restauração de incidentes críticos (MTTR) e número de incidentes críticos no mês
Métrica/indicador operacional	O3 — Uso de recursos da infraestrutura (armazenamento e CPU do servidor de banco de dados do PEP) e O2 — Taxa de sucesso dos backups

Como o operacional explica o estratégico: suponha que a disponibilidade do PEP caiu de 99,9% para 99,2% em um mês (estratégico). No nível tático, observa-se que os incidentes críticos passaram de 1 para 4 e que o MTTR subiu de 1 hora para 3 horas. Ao investigar o operacional, percebe-se que o armazenamento do servidor de banco de dados do PEP estava acima de 90% havia semanas, gerando travamentos, e que os backups vinham falhando por falta de espaço, o que tornava a recuperação mais lenta. Assim, uma métrica operacional aparentemente técnica explica o resultado ruim apresentado à diretoria e apoia uma decisão concreta: ampliar o armazenamento, corrigir o processo de monitoramento de capacidade e justificar o investimento com base no impacto sobre o atendimento.

Parte 6 — Especificação do futuro Dashboard de Governança de TI

Nível	Indicadores selecionados	Por que devem aparecer?	Principal decisão apoiada
Estratégico	E1 Disponibilidade dos sistemas clínicos críticos; E2 Riscos críticos de segurança tratados no prazo; E3 Índice de conformidade com a LGPD	Relacionam a TI aos objetivos do hospital: continuidade do atendimento, segurança e conformidade. Respondem se os investimentos em TI estão gerando resultado	Onde investir, quais riscos tratar ou aceitar e quais projetos priorizar

Nível	Indicadores selecionados	Por que devem aparecer?	Principal decisão apoiada
Tático	T1 Cumprimento de SLA; T2 MTTR de incidentes críticos; T3 Execução orçamentária de TI; T4 Vulnerabilidades críticas corrigidas no prazo	Mostram o desempenho dos processos e serviços de TI e as tendências que explicam os resultados estratégicos	Realocar recursos e equipes, ajustar processos, contratos e orçamento
Operacional	O1 Chamados abertos e atrasados; O2 Taxa de sucesso dos backups; O3 Uso de recursos da infraestrutura; O4 Alertas de acesso suspeito	Permitem agir no dia a dia antes que um problema vire incidente crítico	Ações imediatas: escalonar, corrigir, refazer backup, bloquear acesso

Respostas

1. Qual deverá ser o principal objetivo do dashboard?

Reunir em um só lugar as informações que mostram se a TI está garantindo a continuidade, a segurança e a eficiência dos serviços do hospital, permitindo que cada nível identifique rapidamente o que está acontecendo, por que está acontecendo, qual o impacto e qual decisão deve ser tomada.

2. Quem serão seus principais usuários?

Diretoria executiva, clínica e financeira e o CIO (visão estratégica); gerentes de TI, de infraestrutura e de serviços, CISO e DPO (visão tática); e equipes de service desk, NOC, infraestrutura e segurança (visão operacional). Cada perfil acessa uma visão própria, com a possibilidade de detalhar os níveis abaixo.

3. Qual informação deverá receber maior destaque? Por quê?

A disponibilidade dos sistemas clínicos críticos (E1), acompanhada dos riscos críticos de segurança (E2). Em um hospital, a TI existe principalmente para que o atendimento ao paciente não pare; uma queda no prontuário ou nos exames tem impacto imediato na assistência, e um ataque de ransomware é hoje a principal ameaça a essa continuidade.

4. Como o usuário poderá perceber que determinada situação exige atenção?

Por meio de sinalização em semáforo (verde = dentro da meta, amarelo = atenção, vermelho = limite de alerta ultrapassado), comparação do valor atual com a meta, setas de tendência em relação ao período anterior, destaque no topo da tela para indicadores em vermelho e notificações automáticas (e-mail ou mensagem) para alertas operacionais críticos.

5. Quando um indicador estratégico apresentar um resultado ruim, quais informações táticas e operacionais poderiam ajudar a investigar a causa?

O dashboard deve permitir o detalhamento (drill-down). Se a disponibilidade (E1) cair, consultam-se o MTTR e o número de incidentes críticos por sistema (T2), o cumprimento de SLA (T1) e, no operacional, os alertas e o uso de recursos dos servidores (O3), as falhas de backup (O2) e os chamados abertos relacionados ao sistema (O1). Se os riscos de segurança (E2) piorarem, verificam-se as vulnerabilidades pendentes (T4) e os alertas de acesso suspeito (O4). Assim segue-se o caminho problema → objetivo → indicador → interpretação → decisão.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27002:2022**: Controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27005:2023**: Orientações para gestão de riscos de segurança da informação. Rio de Janeiro: ABNT, 2023.

AXELOS. **ITIL 4**: Foundation. London: TSO, 2019.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. **Lei Geral de Proteção de Dados Pessoais (LGPD)**. Brasília, 2018.

ISACA. **COBIT 2019 Framework**: Governance and Management Objectives. Schaumburg: ISACA, 2018.